

PRATIK SANJAY KHAIRNAR

Cybersecurity Fresher - VAPT (Vulnerability Assessment and Penetration Testing) Engineer

Authentication and Password-Reset Vulnerability Research | Security Tool Development

Nashik, Maharashtra, India | +91-8799981052 | pratik.khairnar.sec@gmail.com | linkedin.com/in/pratik-khairnar-sec | github.com/pratik-khairnar-sec

PROFESSIONAL SUMMARY

Final-year B.Tech Cyber Security and Forensics student and Junior Penetration Tester with hands-on focus on authentication, IDOR/BOLA, and password-reset vulnerability exploitation — token predictability, host-header poisoning, session fixation, and OTP/2FA-flow tampering — built through live VAPT engagements and deepened by independently designing and building **AUTHENTIX v2.1.0**, an enterprise Burp Suite Montoya extension with 27 evidence-gated security invariants, 28 secret analysis rules, and 12 compound ATO chains. Also builds Python security tooling (Reflectra, browser-confirmed XSS scanner; BlindStrike, blind SQL injection framework) to automate vulnerability discovery. Seeking an entry-level VAPT Engineer / Penetration Tester role to apply hands-on exploitation, tooling, and reporting skills.

FLAGSHIP PROJECT - AUTHENTIX

AUTHENTIX - Authentication & IDOR Security Research Suite for Burp Suite

2026

Independent Research | Java, Burp Suite Montoya API, Swing, JUnit 5 | Private repository, code and live demo available on request

- Designed and built an enterprise Burp Suite extension focused on authentication-workflow security (login, OTP, session, password reset, account recovery) and Broken Object Level Authorization (BOLA/IDOR) — addressing critical visibility gaps in legacy scanners.
- Built a per-actor deterministic finite-state automaton, a token-lifecycle tracker (SHA-256 fingerprinted, Shannon entropy analysis), and **27 evidence-gated security invariants** — covering OTP replay, OTP client-trust bypass, session fixation, reset-token reuse, host-header reset poisoning, JWT algorithm confusion, BFLA, and cross-actor enumeration.
- Implemented **28 deep secret analysis rules** (AWS, GCP, Azure, OpenAI, Claude, GitHub, Stripe, Firebase, SendGrid) and an attack-path correlator chaining multi-step findings into **12 real-world Account Takeover (ATO) kill-chains** with real-time Telegram push alerts.
- Validated detection logic against **NimbusBank v2** testbed with 16 working, exploitable vulnerabilities and a standalone JUnit 5 harness with 100% passing tests and zero false positives on secure production traffic.

SECURITY TOOLING PROJECTS

Reflectra - Context-Aware XSS (Cross-Site Scripting) Scanner

v7.0.0

Python, Selenium, Headless Chrome | github.com/pratik-khairnar-sec/Reflectra

- Confirms Cross-Site Scripting (XSS) via real headless-Chrome JavaScript dialog execution, not response string-matching, layered with a context-aware HTTP reflection probe that prioritizes about 2,600 payloads by injection context without dropping coverage on ambiguous probes; adds DOM-sink analysis, authenticated and blind XSS scanning, thread-pooled scanning, and Telegram-delivered HTML reports.

BlindStrike - Blind SQL Injection Testing Framework

v7.0.0

Python | github.com/pratik-khairnar-sec/BlindStrike

- Detects time-based (SLEEP, WAITFOR, pg_sleep) and boolean-based (TRUE/FALSE content-diff, noise-floor normalized) blind SQL injection across MySQL, MSSQL, PostgreSQL, and Oracle, with baseline measurement and confirmation retest; supports URL, POST body, and header injection via a FUZZ marker, multi-threaded scanning, a guided CLI wizard, and JSON/CSV/HTML reporting with real-time Telegram alerts.

PROFESSIONAL EXPERIENCE

Junior Penetration Tester - GROOTT Services

Jun 2025 - Oct 2025

- Performed manual web application penetration testing with Burp Suite to identify, validate, and document OWASP Top 10 vulnerabilities, including broken authentication, broken access control, and injection flaws.
- Tested authentication workflows, including password reset, session management, and login, for logic flaws and token-handling weaknesses; compiled VAPT reports with CVSS-aligned risk ratings and retested fixes before client delivery.

Cyber Crime Intern - Cyber Police Station, Nashik Police Commissionerate

Jan 2026 - May 2026

- Investigated 15+ live cybercrime cases, applying digital forensics techniques for incident investigation and cyber fraud detection; maintained strict chain of custody for digital evidence.
- Conducted network traffic analysis and OSINT investigations to trace ownership behind suspicious websites; performed malware analysis on Android APK evidence and documented indicators of compromise (IOCs) for senior officers.

TECHNICAL SKILLS

Authentication and Access Control: Password Reset Vulnerabilities, Broken Authentication, Session Management, OTP/2FA Bypass, IDOR, JWT Analysis

Web Application Security: VAPT, Manual and Automated Penetration Testing, OWASP Top 10, OWASP ASVS, SQL Injection, Cross-Site Scripting (XSS), Vulnerability Assessment

Security Tool Development: Python (Selenium, Requests, Threading, argparse), Java (Burp Montoya API, Swing, JUnit 5), Telegram Bot API Integration

Security Tools: Burp Suite (including extension development), Nmap, Nessus, Metasploit, SQLMap, Ghauri, Nuclei, Subfinder

Digital Forensics and Investigation: OSINT, Malware Analysis, Network Traffic Analysis, Chain of Custody, Incident Response

Reporting and Standards: CVSS Scoring, Risk Prioritization, Remediation Guidance | **Networking & OS:** HTTP/HTTPS, TCP/IP, DNS, Linux, Windows

EDUCATION & CERTIFICATIONS

B.Tech, Cyber Security and Forensics - Sandip University, Nashik

2023 - Present

Certified Ethical Hacker (CEH v13) - July 2026 | Cisco Certified Network Associate (CCNA) - November 2025